

OVERVIEW OF THE PROCESSING

Controller(s)

Field	Value
Controller	Operator of Scytale/private chat or customer communications deployment
DPO or similar function	Controller DPO or privacy contact
Repository evidence	Consumers/SCYTALE_FYI; chatClient.js; runtime chat migration; patent/mainhub

Name of the Processing

Internal name: Shyware Private Chat / Scytale Communications DPIA

SYSTEMATIC DESCRIPTION OF THE PROCESSING

High-level Description of the Processing

Processed Personal Data

#	Personal Data Item	Data Type / Data Subject Category	Sensitivity
1	Message content	Private communications payload, sealed where configured	High
2	Account/auth data	Login, session, Firebase/Cognito or private-surface auth context	Medium/High
3	Sender/recipient metadata	Conversation participants, timestamps, routing state	High
4	Audit/security logs	Operational and security events	Medium

Purposes of the Processing Provide private communications, account access, message retrieval, security, abuse prevention, and customer support. The customer controls the communication context and legal basis.

Nature, Scope and Context Private messaging creates high metadata risk even where content is sealed. The Scytale/private surface appears to use account authentication and service APIs, so the DPIA must separately assess message confidentiality, metadata minimization, retention, access controls, and lawful disclosure handling.

ANALYSIS OF THE PROCESSING

Lawfulness and Minimisation

Customer controllers must define legal basis and notice language for message content and metadata. Shyware should process message content only under instruction, minimize server-side plaintext, and avoid telemetry that captures message content, participant identifiers, or sensitive metadata.

Mainhub Patent Alignment

The Mainhub patent architecture is useful only where a chat deployment uses canonical two-list records for a specific attestable event or state. It does not make message content, sender/recipient metadata, account sessions, retention stores, lawful-access workflows, or endpoint notifications anonymous. Communications DPIA review must therefore focus on content confidentiality, metadata minimization, retention/export, and legal-hold requirements separately from canonical-state linkage.

Authority Partition This is a sealer-governed embodiment (multi-account, no unique-person count-match). Three parties:

Authority	Role
Auth (Cognito)	Account layer; always required; authentication gate for erasure requests — does NOT h
IDV/KYC (Didit)	Verifies account belongs to a real, verified person; assessed on authenticated users
Reconciling authority	Off-chain linkage store + sealer keys

Because this is a sealer-governed deployment, no eligibility authority key is registered and the rescission mechanism is structurally unavailable. The dual co-authorization constraint does not apply. The worst-case unilateral threat is payload disclosure via the sealer (reconciling authority), not count manipulation.

CONSIDERATIONS ON NECESSITY AND PROPORTIONALITY

The private chat pattern may be proportionate where message confidentiality, account recovery, moderation, abuse reporting, or auditability is necessary for the customer service. It is not proportionate to retain message content, recipient metadata, or legal-hold artifacts beyond the stated purpose. Production should wait until retention/export, endpoint notification, lawful-access, account recovery, and abuse-reporting policies are fixed.

RISK ASSESSMENT AND MANAGEMENT

#	Risk	Required Follow-up
1	Message content exposure	Confirm sealing/E2E posture, key custody, and plaintext boundaries
2	Communications metadata profiling	Define retention, access controls, and minimization for sender/recipient
3	Account takeover	Review authentication, session management, and recovery flows
4	Lawful access overreach	Define request review, logging, and customer instruction process

DPIA Audit Findings

This DPIA is the audit record for private chat and Scytale communications deployments. Before production, the DPIA must identify the provider partition across account/auth provider, message transport, protected linkage store, reconciling authority, canonical commit authority where used, and telemetry/support providers. Canonical-state unlinkability does not reduce risks from message content, sender/recipient metadata, notifications, endpoint compromise, legal hold, abuse reporting, or account recovery. The software evidence for the core kernel may be complete while retention/export, moderation, lawful-access, metadata minimization, and endpoint controls still need to be fixed for this domain.

Operator Compliance Instructions For the non-code governance residuals identified in this DPIA, the operator is instructed by the **Shyware SDK Compliance Guide** (`patent/mainhub/dpia/source/COM` published at <https://shyware.fyi/legal>). Key operator obligations:

- **Art. 6 lawfulness basis** — Identify and document the legal basis for each processing purpose before production. Template in Compliance Guide §Operator Obligations.
- **Art. 28 sub-processor DPAs** — Execute signed DPAs with all subprocessors listed in the generated Records of Processing (`node scripts/generate-rop.mjs -config shyconfig.json`).
- **Art. 30 Records of Processing** — Generate from shyconfig using `generate-rop.mjs`; complete all `REQUIRED_OPERATOR_INPUT` fields; maintain under Art. 30(1).
- **Storage limitation (Art. 5(1)(e))** — Add `retention` block to `shyconfig.json`; configure and operationally enforce the `deletion_cron` schedule.
- **Three-authority key independence** — Verify at scoping-identifier creation that `eligibility_authority_key` $\neq$ `reconciling_authority_key` $\neq$ `auth_key`.
- **Quarterly independent audit** — Engage an independent auditor to verify three-authority operational separation before production.

Residual Risk Assessment

The residual scores below assume the core Shyware twin-kernel controls are implemented and evidence-linked. The software evidence for the core kernel may be complete while message content, metadata, endpoint notification, legal hold, lawful-access, or account-recovery choices

still need to be fixed for this domain. These scores describe residual domain risk after validation; they do not say the kernel tests were missing.

Risk	Additional Measures Applied
Message content exposure	End-to-end or payload sealing, retention limits, and access controls
Sender/recipient metadata linkage	Metadata minimization, provider partitioning, and retention limits
Endpoint or notification leakage	Local controls, notification minimization, and support-export restriction
Lawful access or legal hold overreach	Legal process policy, audit logs, and dual-control reveal
Provider consolidation	Provider matrix for auth, transport, linkage, reconcile, commit, and tele

INVOLVEMENT OF INTERESTED PARTIES

Privacy counsel, security, abuse/moderation stakeholders, support, and customer DPO teams should review this DPIA before production. Data subject consultation may be appropriate where communications involve children, employees, sensitive communities, or high-risk lawful-access contexts.

CONCLUSION AND DECISION

Draft decision: Separate DPIA required before production communications launch. Expand after authentication, sealing, metadata retention, and lawful-access posture are fixed.